



PLANNING DOCUMENT - INTERNAL

Open Questions Decision Brief

Architecture, UX, and product decisions required before the application build begins. Includes the full Gap Assessment question bank mapped to the NIST AI Risk Management Framework.

- i** The following questions must be resolved before the corresponding application screens can be built. OQ-1 and OQ-9 are already resolved - the team has provided sample log files, the domain registry (70 entries, Microsoft Purview sourced), and seeded detection results. Questions OQ-2 through OQ-8 require team decisions.

OQ-1 Sample Log File Format

RESOLVED

RESOLUTION

Sample log files have been created and provided by the team. The domain registry contains 70 entries sourced from the Microsoft Purview supported AI sites list. Seeded detection results are available in both raw and frontend-ready JSON formats. No further action needed on this item.

OQ-2 Risk Scoring Formula

NEEDS DECISION

QUESTION

How are detection results and assessment answers combined into a single overall risk score for the dashboard? What are the weights for each component?

RECOMMENDED FORMULA

Overall Score = (Detection Score × 0.5) + (Assessment Score × 0.5)

Detection Score: High/Unknown tools × 15 pts, Medium × 7 pts, Low × 2 pts (capped 100)

Assessment Score: 100 minus percentage of Yes/Partial answers

With current data: Detection ~74, Assessment ~75 →
Overall: HIGH (74.5)

TEAM DECISION NEEDED

Agree with the 50/50 weighting? Should detections carry more weight than governance answers? Should the Unknown AI tool carry a higher penalty since it cannot be identified?

OQ-3 Gap Assessment Questions - Static or Dynamic?

NEEDS DECISION

QUESTION

Should the 16 governance questions be the same every time (static), or should a small number of additional questions appear based on what categories were detected in the scan?

RECOMMENDATION

Dynamic - add 3 to 4 conditional questions based on detected categories. If image generation tools were found (Midjourney), ask about deepfake policy. If voice/audio tools (ElevenLabs), ask about voice synthesis controls. Adds realism without significant build complexity.

0Q-4

PDF Export Method

NEEDS DECISION

OPTIONS

Browser Print (`window.print()`): Zero extra libraries, uses browser PDF engine, works well with print-optimized CSS. Output quality depends on browser settings.

jsPDF: Full programmatic control, consistent output, but significantly more build time and more things that can fail during a live demo.

RECOMMENDATION

Use browser print for MVP. A dedicated print CSS stylesheet (media print) that hides navigation, applies white backgrounds, and formats report content takes roughly half a day of work. jsPDF can be added post-capstone if a production version is pursued.

0Q-5

Application Structure - Multi-Page vs Single Page App

NEEDS DECISION

OPTIONS

Multi-Page HTML: Separate .html file per step. State passes via localStorage. Each step is independent - if one breaks, others still work. Simplest to build and debug.

Single Page App: One HTML file, JavaScript shows and hides views. Smoother step transitions, all data lives in memory, but one bug can break the entire flow.

RECOMMENDATION

Multi-page HTML with localStorage for state. For a capstone demo timeline, simpler and more demo-reliable is the right tradeoff. A shared step progress bar component makes it feel like one continuous app even across separate pages.

0Q-6

Login Screen vs. Direct to Upload

NEEDS DECISION

OPTIONS

No login: App starts directly at the upload screen. Fastest path to demo content, minimal friction.

Demo login screen: Pre-filled credentials (demo@compass.ai / Compass2026) and a single Sign In button that navigates to upload. Adds realism. Roughly 2 hours of build time.

RECOMMENDATION

Add a minimal login screen. It establishes the product as a real enterprise tool from the first moment, creates a natural demo start point, and takes only 2 hours to build. The login does not need real authentication - just navigate on button click.

0Q-7

Firewall Rule Format for Block Action

NEEDS DECISION

OPTIONS

Generic: Readable by everyone, vendor-neutral.

Palo Alto PAN-OS: Most widely deployed enterprise firewall, recognized by security professionals.

Cisco ASA: Common in mid-market enterprise environments.

Multi-format toggle: Show all three with a format selector in the modal.

RECOMMENDATION

Multi-format toggle: Generic, Palo Alto, and Cisco ASA. The toggle is a small UI component (3 to 4 hours). It shows technical depth to the security-focused audience while keeping a readable generic format for non-technical viewers. This is the same data rendered three ways.

0Q-8SIEM Query Format for Monitor Action		NEEDS DECISION
OPTIONS Splunk SPL: Largest installed SIEM base in enterprise. SPL queries are recognizable to most security professionals. Microsoft Sentinel KQL: Fastest growing enterprise SIEM. KQL is familiar to Microsoft shop audiences. Generic alert description: Non-technical explanation of what the alert does.		RECOMMENDATION Show Splunk SPL and Microsoft Sentinel KQL with a platform toggle, plus a generic description tab. Query text is already drafted in the PRD. This covers the two most common enterprise SIEMs and ensures the demo resonates with any security audience.
0Q-9Sample Log Files for Demo		RESOLVED
RESOLUTION Sample log files have been provided. Detection results cover 13 tools across DNS, proxy, and firewall log sources with 210 total events across 5 observed users (asmith, guest, jdoe, mchen, rpatel) and 5 source IPs. No further action needed.		

DECISION SUMMARY

#	QUESTION	RECOMMENDATION	STATUS	TEAM OK?
0Q-1	Sample log file format	Resolved - files provided	✓	
0Q-2	Risk scoring formula	Detection 50% + Assessment 50%	●	
0Q-3	Static vs dynamic questions	Dynamic - 3 to 4 conditional questions	●	
0Q-4	PDF export method	Browser print with print CSS	●	
0Q-5	App structure	Multi-page HTML + localStorage	●	
0Q-6	Login screen	Yes - simple demo login (2 hrs)	●	
0Q-7	Firewall block format	Multi-format toggle (Generic, Palo Alto, Cisco)	●	
0Q-8	SIEM monitor format	Splunk + Sentinel toggle + generic	●	
0Q-9	Demo log files ownership	Resolved - files provided	✓	

i 16 governance questions mapped to the four NIST AI RMF functions: Govern, Map, Measure, and Manage. Each "No" or "Unsure" answer generates a finding with a risk level and recommended action. Answer options: **Yes** (100 pts) / **Partial** (50 pts) / **No** (0 pts) / **Unsure** (0 pts, flagged for follow-up).

GOVERN **Organizational Policies and Accountability** *Does the org have policies and ownership structures for AI?*

ID	QUESTION	NIST REF	GAP IF "NO"
6-01	Does your organization have a written AI usage policy that defines approved and prohibited uses?	Govern 1.1	HIGH
6-02	Is there a designated owner or team responsible for AI governance decisions?	Govern 1.2	MEDIUM
6-03	Are employees required to review and acknowledge AI usage policies?	Govern 1.3	MEDIUM
6-04	Does your organization review and update AI policies at least once per year?	Govern 1.7	LOW

MAP **AI Tool Inventory and Risk Awareness** *Does the org understand what AI is in use and what risks those tools carry?*

ID	QUESTION	NIST REF	GAP IF "NO"
M-01	Has your organization formally inventoried all AI tools in use across departments?	Map 1.1	HIGH
M-02	Have the data handling practices of each AI tool in use been reviewed?	Map 1.5	HIGH
M-03	Do you understand which AI tools have access to sensitive or confidential company data?	Map 2.2	HIGH
M-04	Has a formal risk assessment been conducted for any AI tool currently in use?	Map 5.1	MEDIUM

MEASURE Monitoring and Ongoing Risk Measurement		Does the org actively monitor and measure AI risk over time?	
ID	QUESTION	NIST REF	GAP IF "NO"
ME-01	Is AI tool usage monitored in your SIEM, proxy, or equivalent logging system?	Measure 2.5	HIGH
ME-02	Do you receive alerts when new or unknown AI tools are accessed on the network?	Measure 2.6	HIGH
ME-03	Are AI-related security incidents tracked and reviewed on a regular schedule?	Measure 4.1	MEDIUM
ME-04	Do you conduct periodic reviews of the AI tool inventory to check for newly adopted tools?	Measure 2.2	MEDIUM

MANAGE Response and Remediation Capability		Does the org have the processes to act on AI risk?	
ID	QUESTION	NIST REF	GAP IF "NO"
MG-01	Does your organization have a defined process to block or restrict unauthorized AI tools?	Manage 1.3	HIGH
MG-02	Is there a vendor review process for AI tools before organizational adoption?	Manage 2.2	HIGH
MG-03	Do you have an incident response plan that covers AI-related data exposure events?	Manage 3.1	MEDIUM
MG-04	Are AI tool owners formally assigned to maintain accountability for each approved tool?	Manage 4.1	MEDIUM

CONDITIONAL QUESTIONS - TRIGGERED BY DETECTED TOOL CATEGORIES

→

These questions appear only if specific tool categories were detected during the scan. They are added at the end of the relevant NIST section.

ID	QUESTION	TRIGGER CONDITION	NIST REF	GAP IF "NO"
C-01	Do you have a policy that addresses AI-generated media, including deepfakes and synthetic images?	Image Generation tool detected (e.g., Midjourney)	Govern 1.1	HIGH
C-02	Do you have controls in place around AI voice synthesis or audio cloning tools?	Audio Generation tool detected (e.g., ElevenLabs)	Govern 1.1	HIGH
C-03	Are guest and contractor accounts restricted from accessing AI tools on the corporate network?	"guest" user observed in detection results	Manage 1.3	HIGH
C-04	Do you have a process to investigate and identify unrecognized or unclassified AI tool traffic?	Unknown/unclassified domain detected in logs	Map 1.1	HIGH